

PARA O ALTO E AVANTE

GERENCIAMENTO DE INCIDENTES DE SEGURANÇA



11

LISTA DE FIGURAS

Figura 1 – Disco contendo o código do malware Morris Worm – Boston Museum of Science	4
Figura 2 – Tratamento de incidentes de segurança e CSIRT.....	9
Figura 3 – Processo de tratamento de incidentes de segurança.....	11

EMANSP

SUMÁRIO

1 GERENCIAMENTO DE INCIDENTES DE SEGURANÇA.....	4
1.1 Introdução	4
2 O QUE É UM INCIDENTE DE SEGURANÇA?	5
3 TRATAMENTO E RESPOSTA A INCIDENTES DE SEGURANÇA	7
3.1 Plano de resposta a incidentes de segurança.....	8
3.2 Etapas do processo de resposta	9
3.3 Gerenciamento de incidentes de segurança	11
CONCLUSÃO.....	12
REFERÊNCIAS.....	13

1 GERENCIAMENTO DE INCIDENTES DE SEGURANÇA

1.1 Introdução

Em 1988, foi identificado um dos primeiros malwares distribuídos pela Internet, o Morris Worm. Esse malware, que infectou cerca de 10% dos computadores conectados à Internet na época, foi escrito por um estudante da Universidade Cornell (EUA) e consistia em uma combinação de DDoS, exploits, técnicas de exploração furtivas, entre outros processos ainda muito utilizados nos malwares atuais.



Figura 1 – Disco contendo o código do malware Morris Worm – Boston Museum of Science
Fonte: Kaspersky (2013)

O caso Morris Worm, como ficou conhecido, levou à primeira condenação por fraude na informática dos Estados Unidos da América, sob a Lei de Abuso. Robert Tappan Morris foi condenado a três anos de liberdade condicional, US\$ 10 mil em multas e 400 horas de serviço comunitário. Essa pena, considerada branda, levou em consideração a não intencionalidade do caso. O Morris Worm não foi escrito com a finalidade de causar danos, mas um erro de programação ocasionou a disseminação na rede a partir de um único computador sem ser detido (vírus), acarretando a sobrecarga no servidor e a posterior negação de serviço (DDoS).

O incidente proporcionou a criação de dois grupos de trabalho com a finalidade de encontrar e corrigir as vulnerabilidades exploradas pelo malware. As equipes, apesar da inexperiência relativa a esse tipo de incidente, agiram rapidamente, en-

contrando e corrigindo o problema em apenas dois dias. O custo de remoção dessa infecção foi alto: aproximadamente US\$ 10 milhões.

Esse caso emblemático ilustra muito bem como o gerenciamento do incidente de segurança é fundamental para saná-lo. Equipes bem treinadas, aptas e apropriadas são um fator decisivo na gestão desse tipo de crise. Apesar dos esforços, o custo tende a ser bem alto, aumentando a necessidade de rapidez na resposta, o que pode ser alcançado com times bem treinados, metodologias claras e eficientes e a construção da mentalidade de continuidade no esforço de desenvolvimento de ferramentas que acompanhem a velocidade de surgimento de novas ameaças.

2 O QUE É UM INCIDENTE DE SEGURANÇA?

Incidentes de segurança são quaisquer eventos adversos, confirmados ou ainda sob suspeita, que geram risco a uma entidade de informação, relacionados à segurança de redes de computadores ou de sistemas de computação.

São situações como:

- Evasão de informações confidenciais;
- Mensagens de spam com conteúdo malicioso;
- Propagação de worms ou vírus utilizando lista de contatos de e-mails;
- Desfiguração de sites ou portais;
- Ataques de negação de serviço;
- Uso ou acesso não autorizado a um sistema;
- Uso ou acesso não autorizado à informação;
- Tentativas de ganhar acesso não autorizado a sistemas ou dados;
- Mal funcionamento de um sistema ou perda de um serviço;
- Mudanças não controladas em sistemas;
- Escaneamento de portas de rede não autorizado;
- Computador infectado com vírus ou outro tipo de malware;
- Engenharia social para obtenção de acesso a dados da organização;

- Falsificação ou destruição de registros institucionais;
- Alteração em dados por pessoa não autorizada;
- Dano ou interrupção proposital de serviços ou equipamentos da organização;
- *Deface* ou pichação em website;
- Acesso a sistemas utilizando credenciais alheias;
- Acesso a ambiente restrito (sala de servidores, por exemplo);
- Compartilhamento de dispositivos confidenciais, de senhas ou tokens;
- Dar ou permitir acesso a pessoa não autorizada;
- Material falsificado ou que infringe direitos autorais;
- Acesso a conteúdo ou material inapropriado na internet;
- Recebimento de material de natureza ofensiva (pornografia, racismo ou conteúdo violento);
- Violações às políticas de segurança da empresa ou práticas não autorizadas;
- Roubo ou furto de dados ou equipamentos da instituição.

A grande quantidade de situações nos faz ter uma ideia do desafio que as equipes que lidam diariamente com o gerenciamento de incidentes de segurança encontram.

Os incidentes de segurança podem, ainda, ser internos ou externos:

Internos: são os incidentes de segurança que possuem maior probabilidade de êxito, tendo em vista o conhecimento prévio por parte do atacante da estrutura interna da instituição, utilizando, muitas vezes, acesso privilegiado a ativos e sistemas que garantem a maior probabilidade de sucesso de tal ataque. São muito comuns situações como testes e experimentos com ferramentas sem prévia autorização ou sem as devidas precauções de segurança, com ou sem a intenção de causar danos, ou até mesmo roubo de informações confidenciais com as mais diversas finalidades.

Externos: são originados de fora da instituição, ou seja, extrapolam o domínio administrativo da instituição. Podemos citar, nesse caso, a exploração de vulnerabilidade após varredura em servidores de uma corporação, por exemplo. Esse tipo pressupõe uma maior dificuldade de êxito, mas pode se valer de mecanismos complexos ou simples, como engenharia social, para obter acesso aos meios informacionais desejados.

Cabe ressaltar, ainda, que a **severidade** de um incidente pode ser mensurada levando em conta o impacto que ele causa no processo de negócio de uma instituição. Todo incidente deve ser tratado, necessitando, para isso, de metodologias previamente definidas pela instituição. Chamaremos essa metodologia de processo de resposta a incidentes de segurança.

3 TRATAMENTO E RESPOSTA A INCIDENTES DE SEGURANÇA

O processo de resposta a um incidente de segurança, que envolve seu tratamento utilizando uma metodologia predefinida e organizada para gerir consequências de uma determinada violação de segurança da informação, tem por objetivo minimizar os impactos do incidente, permitindo assim um rápido restabelecimento dos sistemas.

Quando um incidente é reportado por um cliente ou usuário a uma central de serviços, por exemplo, é indicativo de que o serviço que é provido foi interrompido ou está com um comportamento anômalo, ou seja: está se comportando de uma forma não desejada (baixa velocidade no acesso, interrupção por queda de link, erros em sistemas, entre outros).

Dessa forma, sempre que um incidente – ou seja, uma anomalia – acontece em algum serviço, devemos acompanhar de perto o problema a fim de evitar "dores de cabeça" em relação à qualidade do serviço. Deve-se, portanto, considerar a volta do serviço no menor tempo possível. O tempo de restauração do serviço torna-se, desse modo, um item importante que deve ser contemplado para a gestão dos incidentes.

Um incidente não é algo desejado, porém, quando acontece, deve ser prontamente atendido e todas as medidas necessárias para sanar o problema devem ser

tomadas, a fim de evitar perdas ou prejuízos às organizações envolvidas, tanto a prestadora quanto a tomadora do serviço.

A quantidade de incidentes registrada para um serviço está **diretamente relacionada à qualidade desse serviço**. Se temos um serviço estável, que se comporta de maneira adequada na maior parte do tempo, principalmente nos momentos em que o serviço é mais requisitado, isso indica que o serviço é de boa qualidade, é bem provido, é controlado e suporta bem a carga que lhe é aplicada. Mas, em contrapartida, se temos um serviço que geralmente ou com frequência apresenta indisponibilidade, ou que tem problemas no momento que é tomado, isso geralmente indica que esse serviço não é de boa qualidade. Temos, nesse último caso, um excelente indicativo de que esse serviço deve ser revisto e melhorado.

A gestão de incidentes disponibiliza uma série de **indicadores de desempenho** que podem mostrar e evidenciar, ao longo do tempo, a qualidade dos serviços que são providos. Evidentemente que temos a quantidade de incidentes ocorridos e reportados num determinado período como um dos principais indicadores. Porém, o tempo em que a disponibilidade foi afetada também é um indicador e a gravidade dos incidentes também deve ser considerada. Alguns incidentes possuem grande impacto, outros apresentam impacto mínimo.

Serviços com uma grande quantidade de incidentes registrados promovem a entrada em cena de processos de gestão de incidentes, mas a quantidade, a volumetria, a forma com que os chamados são atendidos, o tempo médio de atendimento e até mesmo o tempo de inatividade dos serviços por conta de incidentes são indicadores que devem ser observados.

3.1 Plano de resposta a incidentes de segurança

Definir a política de segurança é uma etapa fundamental no desenvolvimento de um plano de resposta a incidentes de segurança. Da mesma forma, também é importante definir claramente as etapas desse processo de resposta.

É fundamental, ainda, que exista na etapa de definição do processo de resposta: sinergia das diversas equipes, incluindo níveis gerenciais e técnicos, culminando na implementação do chamado “time de resposta a incidentes”, o CSIRT

(*Computer Security Incident Response Team*), com integrantes cuidadosamente selecionados, incluindo, além dos analistas de segurança, representantes legais, entre outros julgados necessários ao processo de resposta.

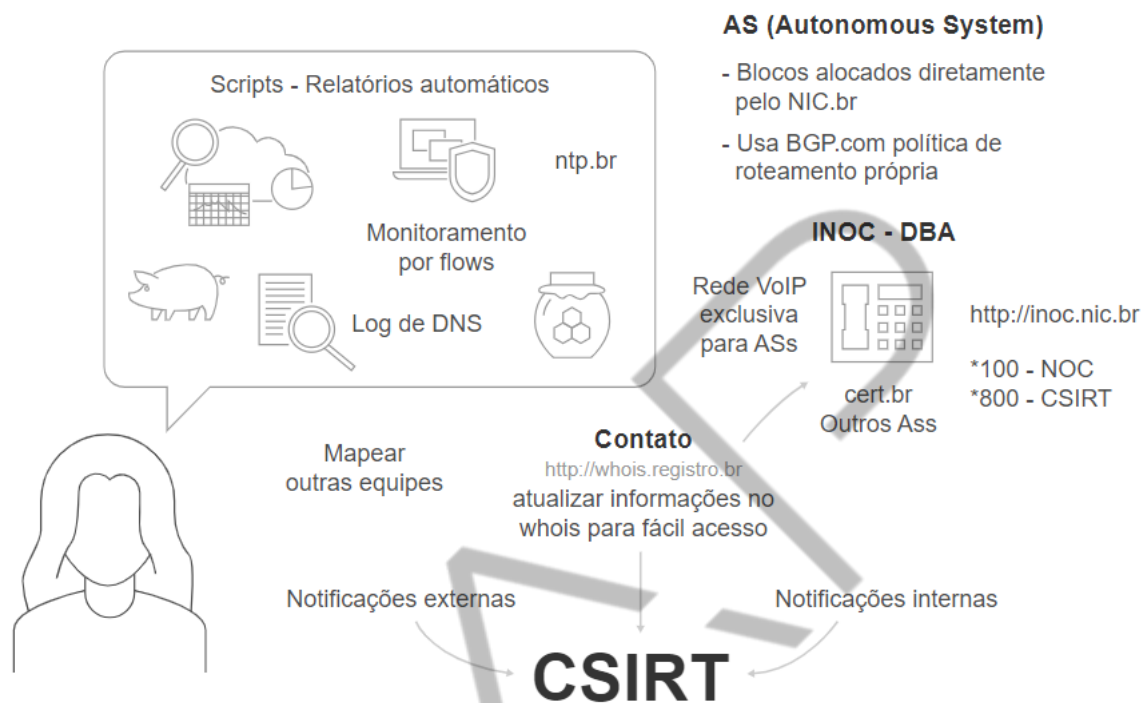


Figura 2 – Tratamento de incidentes de segurança e CSIRT

Fonte: NIC.br (2021)

Saiba mais: O site do NIC.br é bem completo, com vários vídeos e animações. Vale uma visita para entender melhor o tema:

<<https://nic.br/videos/categoria/seguranca/>>

3.2 Etapas do processo de resposta

Podemos dividir o processo de resposta a incidentes de segurança em cinco etapas. São elas:

Identificação: essa etapa pressupõe a identificação do incidente de segurança. A equipe deve identificar os sintomas do ataque, as características e a severidade (o quanto da estrutura de negócios da organização foi afetada). Para tanto, a equipe pode se basear em monitoramentos utilizando ferramentas específicas, notificações externas ou internas, sistemas de detecção de intrusão, entre outros aspectos. Cabe à equipe criar e manter uma base de conhecimento de incidentes, tendo

em vista as peculiaridades da organização em que atuam. Essa base de registros de incidentes passados será de grande utilidade em eventos futuros, considerando o levantamento de informações iniciais de incidentes, características e sintomas.

Coordenação: essa etapa é a responsável pela elaboração de linhas de ação que possivelmente devem resolver o incidente em andamento. Após a etapa inicial de detecção e identificação, são realizados diagnósticos a fim de gerar análises que levarão a conclusões sobre quais ações serão tomadas.

Mitigação: nessa fase, são tomadas as medidas julgadas necessárias para sanar o incidente, mesmo que temporariamente, até que uma solução definitiva seja implementada. É aqui que o incidente é isolado, utilizando procedimentos que evitem a propagação do ataque, e a extensão dos danos é determinada. É realizado, ainda nessa etapa, o restabelecimento do sistema ou serviço.

Investigação: realizada a mitigação do incidente, é hora de coletar e analisar as evidências do incidente de segurança (registros, logs, pacotes capturados, entrevistas com envolvidos no incidente, etc.). Essa fase é importante, inclusive, em eventos futuros, em incidentes com características semelhantes e que podem compor a base de conhecimentos da organização.

Educação: é nessa etapa, por fim, que é avaliado não apenas o processo de tratamento dos incidentes, mas também a eficácia das soluções que foram implementadas no decorrer das etapas anteriores, com a finalidade de melhoria contínua e como forma de propagação e disseminação das lições aprendidas para toda a equipe.

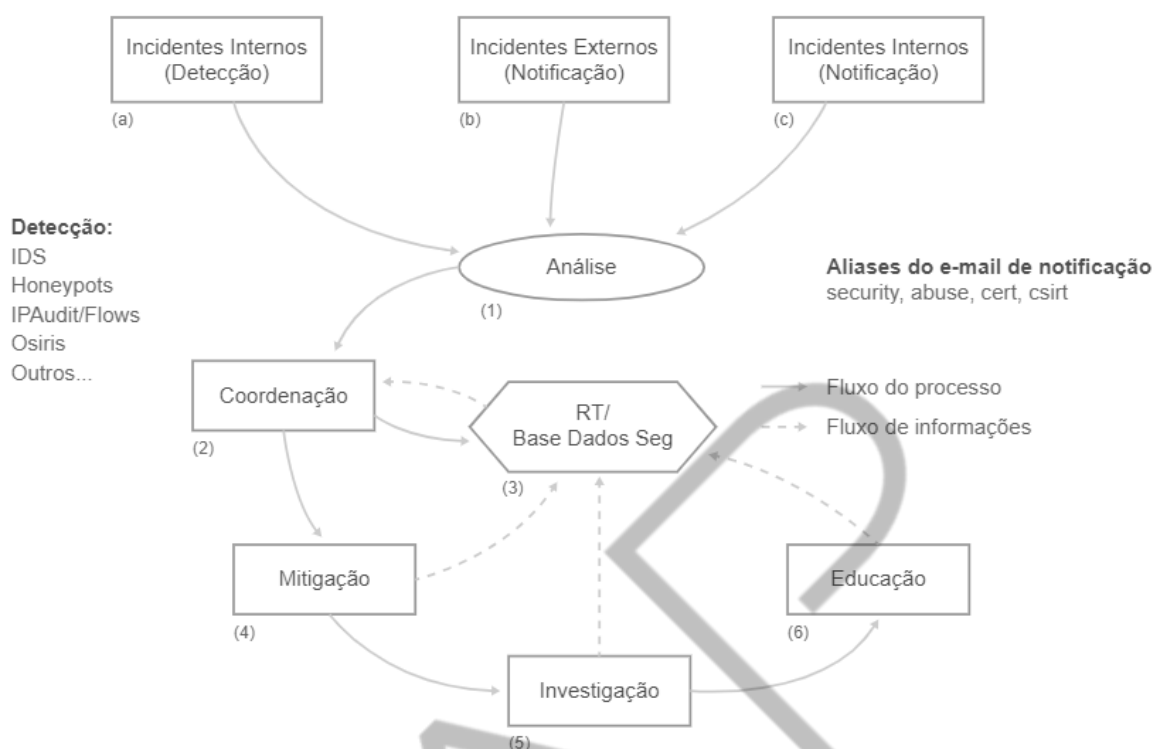


Figura 3 – Processo de tratamento de incidentes de segurança
Fonte: Ceron (2009)

3.3 Gerenciamento de incidentes de segurança

Mas, afinal, o que é Gerenciamento de Incidentes? A resposta para essa pergunta é clara e desencadeia uma série de processos que culminarão em um ambiente mais seguro de negócios: é um conjunto de processos necessários para controlar ou administrar as tarefas associadas ao tratamento de incidentes de segurança.

Esses processos pressupõem a realização de serviços proativos e reativos que auxiliam no desenvolvimento de tratamento de incidentes de segurança. Envolvem, normalmente, os processos de **preparação, proteção, detecção, triagem e resposta**.

CONCLUSÃO

Como podemos perceber, o Gerenciamento de Incidentes de Segurança é um tema vital em um mundo cada vez mais conectado e cada vez mais dependente da informação. A gestão do incidente pressupõe a preparação e investimentos em capacitação, equipamentos e ferramentas adequadas.

O tempo de resposta e a eficiência das medidas adotadas serão diretamente proporcionais aos custos e aos danos que determinado incidente de segurança acarretará à organização. A imagem dela perante seus clientes será afetada na mesma medida em que se preparou para lidar com problemas de segurança que, apesar de qualquer esforço e independentemente de sua vontade, estão cada vez mais comuns nos dias atuais.

Neste capítulo, nosso objetivo foi explorar o tema, introduzindo alguns conceitos e a ideia principal por trás da necessidade de planejamento para lidar com problemas desse tipo.

REFERÊNCIAS

CERON, J. et al. **O processo de tratamento de incidentes de segurança da UFRGS**. 2009. Disponível em: <<https://www.lume.ufrgs.br/bitstream/handle/10183/16096/000696922.pdf?sequence=1>>. Acesso em: 13 jun. 2024.

CERT.br. **Cartilha de Segurança para Internet**. 2002. Disponível em: <<http://www.cartilha.cert.br>>. Acesso em: 13 jun. 2024.

CSIRT UFPA. **Pergunta frequentes**. 2018. Disponível em: <<https://ufla.br/acessoainformacao/destaques/perguntas-frequentes22>>. Acesso em: 13 jun. 2024.

MALENKOVICH, S. **Caso Morris Worm completa 25 anos**. 2013. Disponível em: <<https://www.kaspersky.com.br/blog/caso-morris-worm-completa-25-anos/1632/>>. Acesso em: 13 jun. 2024.

NIC.BR. **Tratamento de Incidentes de Segurança explicado pelo NIC.br**. Disponível em: <<https://www.nic.br/videos/ver/tratamento-de-incidentes-de-seguranca-na-internet-explicado-pelo-nic-br/#:~:text=Tratamento%20de%20Incidentes%20de%20Seguranca%20na%20Internet%2C%20explicado%20pelo%20NIC.br,-Publicado%20em%2010&text=O%20trabalho%20de%20uma%20equipe,sempre%20prontos%20para%20apag%C3%A1%20Dios%E2%80%A6>>. Acesso em: 13 jun. 2024.